

Riigi Infosüsteemi Amet
eID osakond / Küberturvalisuse teenistus (Järelevalveosakond)
Pärnu mnt 139a, 15169 Tallinn
ria@ria.ee

MÄRGUKIRI

08.04.2026

Lugupeetud Riigi Infosüsteemi Ameti eID ja järelevalve valdkonna juhid

Pöördun Teie poole, et juhtida tähelepanu Eesti digiidentiteedi ökosüsteemis tekkinud struktuursele turutörkele, mis jätab Eesti elanikud ja finantssektori tarbetult avatuks massilistele automatiseeritud õngitsusrünnetele (AiTM – Adversary-in-the-Middle).

Probleemi tuum ei ole tehnoloogiline, vaid äriline. Tehniline konsensus on saavutatud: Smart-ID v2 teavitustepõhine voog on pärandtehnoloogia, mille andmepüügivastane kaitse ei vasta tänapäevasele ohupildile, samas kui v3 (QR/App-to-App) maandab need riskid. Paraku näitab turu käitumine, et erasektor ei suuda isereguleeruvalt turvalisemale lahendusele üle minna, mistõttu on vajalik RIA kui riikliku järelevalveasutuse strateegiline ja sihistatud sekkumine.

1. Probleemi olemus: Lepinguline ummseis ja turutörge

Praktika näitab, et SK ID Solutions AS (SK) ei suuda ega soovi iseseisvalt v2 pärand-API-t sulgeda, kuna nad on seotud pikaajaliste teenuslepingutega (SLA) eraõiguslike e-teenuste pakkujatega (RP – Relying Parties). Paljud neist teenusepakkujatest keelduvad eraldamast IT-arenduse ressursse oma süsteemide (nt e-poed, iseteenindusportaalid, kliendibaasid) migreerimiseks turvalisemale v3 voole.

See on klassikaline turutörge:

Teenusepakkujad (RP-d) hoiavad kokku lühiajaliste arenduskulude pealt, jätkates v2 kasutamist. SK ID Solutions ei saa v2 voogu ühepoolselt sulgeda ilma lepinguid rikkumata ja ärikliente kaotamata või pahandamata.

Pankadele ja kodanikele eksternaliseeritakse kogu risk ja kulu. Ründajad kasutavad v2 kaudu kaaperdatud PIN1 sessioone (pääsedes ligi isikuandmetele) edukaks sotsiaalinseneeriaks, et petta kasutajatelt välja PIN2 ja teostada finantspettusi, mille kahjud kannab lõpuks finantssektor ja ühiskond.

Äriline mugavus trumpab hetkel üle riikliku küberturvalisuse. SK on langenud omaenda pärandlepingute pantvangiks ning vajab väljastpoolt tulevat regulatiivset tõuget, et olukorda lahendada.

2. Küberturvalisuse seadus (KÜTS/NIS2) ja RP-de vastutus

Alates NIS2 direktiivi ülevõtmisest ja KÜTS-i kaasajastamisest on oluline osa Smart-ID-d kasutavatest teenusepakujatest (nt telekomid, energiaettevõtted, suured e-kaubanduse platvormid, elutähtsa teenuse osutajad) seaduse mõistes olulised või elutähtsad üksused.

KÜTS § 15 kohustab neid rakendama proportsionaalseid ja tehnika arengutasemele (state of the art) vastavaid turvameetmeid. Mitmefaktoriline autentimine (MFA), mis on vastuvõtlik lihtsatele puhverserveri rünnete ajal, mil teenuseosutaja (SK) pakub ametlikult andmepüügikindlamat alternatiivi (v3), ei vasta enam tehnika arengutasemele. Seega ei ole probleem mitte ainult SK-s, vaid eelkõige KÜTS-i kohuslastest teenusepakujates, kes eiravad oma hoolsuskohustust.

3. Taotletavad sammud: Regulatiivne hoob SK vabastamiseks

Selle turutõrke lahendamiseks ei ole vaja RIA-l algatada SK suhtes ründavat järelevalvemenetlust. SK vajab, et RIA "teeks n-ö halba politseid" ja annaks neile juriidilise argumenti (nn regulatiivse force majeure'i), millele toetudes saavad nad oma kliente sundida uuendusi tegema.

Teeme RIA-le ettepaneku astuda järgmised proportsionaalsed ja halduslikult teostatavad sammud:

Ametliku järelevalvesuunise (Juhise) väljastamine: Palume RIA-l (koostöös CERT-EE-ga) avaldada ametlik suunis, mis deklareerib selgelt, et Smart-ID v2 teavitustepõhine autentimisvoog ei vasta enam KÜTS-is nõutud tehnika arengutasemele ning seda ei tohiks kasutada isikuandmete, finantsandmete või muude tundlike süsteemide autentimiseks. Mõju: See suunis annab SK-le seadusliku ja regulatiivse aluse (haldusorgani ettekirjutus/suunis) käivitada oma API deprecation-plaan ja nõuda RP-delt migreerumist v3-le, ilma et see liigituks lepingurikkumiseks.

KÜTS kohuslaste auditeerimise fookus: Lisada RIA regulaarsetesse KÜTS-i kohuslaste järelevalveaudititesse kontrollküsimus autentimislahenduste turvalisuse (sh v3 kasutamise) kohta. Kui oluliste teenuste osutajad tajuvad, et RIA käsitleb v2 kasutamist auditi puudusena, teevad nad migratsiooniotsuse ise ja kiiresti.

Koostöö Finantsinspeksiooni ja Pangaliiduga: Kaasata diskussiooni pangad, kes kannavad peamist rahalist ja mainekahju. SK tuumikomanike (suurpankade) huvides on pettuste vähendamine. RIA ametlik suunis aitab pankade pettustevastastel osakondadel (Fraud Departments) survestada SK juhtkonda API sulgemise tähtaegu paika panema.

Kokkuvõte

Eesti ei saa lubada olukorda, kus riiklik eID ökosüsteem stagneerub ja küberkuritegevus õitseb vaid seetõttu, et osad erasektori e-teenused keelduvad tasumast oma IT-süsteemide kaasajastamise kulusid, hoides SK-d pärandlepingutega lõksus.

Käesolev märgukiri pakub RIA-le võimaluse lahendada see ummseis elegantselt – luues ametliku regulatiivse ootuse, mis sunnib turgu liikuma, vabastab SK lepingulistest käeraudadest ja tõstab hüppeliselt kogu riigi e-teenuste turvataset.

Olen valmis soovi korral teemat täpsustama ning kohtuma RIA vastavate spetsialistidega.

Palun vastata mulle kirjalikult e-postiga.

Lugupidamisega

(allkirjastatud digitaalselt)

Tom Kristian Abel
Märgukirja esitaja

Tom Kristian Abel

Lisad:
